Solicitudes de derechos ARCOP

Historia de usuario: *como Titular de Datos Personales quiero registrar solicitudes formales de Acceso, Rectificación, Supresión, Oposición, Portabilidad o Bloqueo para garantizar el cumplimiento de los derechos de la Ley N.º 21.719.*

- **Versión 1** (migración `e5a1c9d4b2f7`): solicitudes, ciclo de vida, historial, roles.
- **Versión 2** (migración `f7b2d1a8c3e9`):
  1. El usuario temporal obtiene su token con los datos de su invitación y el administrador inicia sesión con email y contraseña (tabla `usuarios_admin`).
  2. Una **supresión aprobada** (`resuelta`) anonimiza los datos del titular.
  3. Plazos de respuesta y de aporte de información **configurables y vacíos** hasta que el equipo los defina.
- **Versión 3** (migración `b3c8e5d2a7f1`, revisa `9a4e2c7b1f05`) — cierra lo pendiente de la HU-08:
  1. **Código de seguimiento único** por solicitud (`ARC-XXXX-XXXX`) y consulta pública del estado sin login ni datos personales: `GET /api/arcop/seguimiento/{codigo}`.
  2. **Plazos legales por defecto** (Ley 21.719): respuesta en **30 días corridos**, **prórroga única** de 30 días con motivo (`POST .../prorroga`), y **bloqueo temporal en 2 días hábiles**.
  3. **Acceso del encuestado anónimo** de la encuesta pública (rol `encuestado`): entra con el id de su evaluación y una **clave de acceso** (`POST /api/auth/encuestado`). El acceso por invitación se mantiene.

Versión 3 en detalle

Código de seguimiento

- Se genera al crear la solicitud: `ARC-` + 8 caracteres al azar (alfabeto sin I, L, O, U), 40 bits.

  No revela el id ni el orden de llegada. Columna `codigo_seguimiento` con restricción `UNIQUE`.
- `GET /api/arcop/seguimiento/{codigo}` (público): acepta minúsculas, espacios y sin guiones.

  Devuelve solo `codigo_seguimiento`, `tipo`, `estado`, fechas, `fecha_limite_respuesta`, `prorrogada` y `plazo_vencido`. **Nunca** la descripción, la respuesta, ids ni datos del titular.
- Las solicitudes que ya existían reciben un código en la migración.

Plazos legales

Variable (`.env`, opcional)	Defecto	Qué hace
`ARCOP_PLAZO_RESPUESTA_DIAS`	30	Días **corridos** desde que se recibe la solicitud
`ARCOP_PLAZO_PRORROGA_DIAS`	30	Días que agrega la prórroga (una sola vez)
`ARCOP_PLAZO_BLOQUEO_DIAS_HABILES`	2	Plazo del bloqueo temporal, de lunes a viernes
`ARCOP_PLAZO_INFORMACION_DIAS`	vacío	Plazo del titular para aportar antecedentes (la ley no lo fija)

- **Prórroga** (`POST /api/arcop/solicitudes/{id}/prorroga`, solo admin, `{"motivo": "..."}`): una sola vez,

  antes de que venza el plazo, con la solicitud abierta. No aplica al bloqueo. Queda en el historial (evento `prorroga`) y en `fecha_prorroga`.
- **Días hábiles:** se cuentan de lunes a viernes, **sin descontar feriados** (no hay calendario de feriados

  en el proyecto). Las fechas se guardan en UTC.
- El plazo **sigue corriendo** mientras la solicitud está en `pendiente_informacion` (la ley no dice que se

  suspenda; ver decisiones).
- Las solicitudes abiertas que no tenían plazo reciben el legal en la migración (desde su fecha de creación).
- Solo se **informa** el vencimiento (`plazo_vencido`, `?vencidas=true`); no hay cierre automático.

Acceso del encuestado anónimo (encuesta pública)

Paso	Endpoint	Quién
1. Generar la clave de una evaluación	`POST /api/auth/encuestado/clave` `{"evaluacion_id": N}`	admin (hoy); HU-19 lo hará al crear la evaluación pública
2. Obtener el token	`POST /api/auth/encuestado` `{"evaluacion_id": N, "clave": "XXXX-XXXX-XXXX"}`	encuestado
3. Usar ARCOP	los mismos endpoints `/api/arcop/...` que el invitado	encuestado

- La clave se muestra **una sola vez**; en BD se guarda solo su hash PBKDF2 (`evaluacion.clave_acceso_hash`).

  Generar otra invalida la anterior. Se aceptan minúsculas, espacios y confusiones O/0, I/L/1.
- La solicitud de un encuestado queda ligada a `Evaluacion_id` (y `Usuario_temporal_id` en NULL);

  un `CHECK` exige exactamente uno de los dos. Cada titular ve solo las suyas (404 para las ajenas).
- **Supresión aprobada de un encuestado:** se anonimiza **solo su evaluación** (justificaciones, evidencias

y archivos, mapa cifrado, extractos de seguridad, sus solicitudes) y se borra su clave: pierde el acceso y sus tokens dejan de servir. Si el titular es un invitado, se anonimizan todas sus evaluaciones (como antes) y también se borran las claves de esas evaluaciones.

- Para la HU-19: llamar a `generar_clave_acceso(db, evaluacion_id)` (`app/application/use_cases/clave_acceso_encuestado.py`) al crear la evaluación pública y mostrar la clave al encuestado una vez.

Archivos de la versión 3

Tipo	Archivo
nuevo	`app/application/use_cases/clave_acceso_encuestado.py`
nuevo	`migrations/versions/b3c8e5d2a7f1_hu08_codigo_plazos_encuestado.py`
modificado	`app/domain/models/solicitud_arcop.py` · `app/domain/models/evaluacion.py`
modificado	`app/core/autenticacion.py` (rol `encuestado`) · `app/core/config.py` (plazos)
modificado	`app/application/use_cases/gestionar_solicitud_arcop.py` · `iniciar_sesion.py`
modificado	`app/application/schemas/arcop_schemas.py` · `app/api/routes/arcop.py` · `app/api/routes/auth.py`
modificado	`app/infrastructure/repositories/solicitud_arcop_repository.py` · `anonimizacion_repository.py`
modificado	`.env.example` · `tests/test_solicitudes_arcop.py` (13 pruebas nuevas) · `CAMBIOS_ARCOP.md`

Archivos de la versión 2

Tipo	Archivo	Qué hace
nuevo	`app/domain/models/usuario_admin.py`	Administradores con contraseña (hash PBKDF2-SHA256)
nuevo	`app/core/crear_admin.py`	CLI para crear, cambiar contraseña o desactivar un admin
nuevo	`app/application/use_cases/iniciar_sesion.py`	Login del admin y acceso del titular
nuevo	`app/api/routes/auth.py`	`POST /api/auth/login`, `POST /api/auth/titular`, `GET /api/auth/me`
nuevo	`app/infrastructure/repositories/anonimizacion_repository.py`	Anonimiza todos los datos de un titular (sin commit propio)
nuevo	`migrations/versions/f7b2d1a8c3e9_arcop_admin_plazos_anonimizacion.py`	Tabla `usuarios_admin` y columnas nuevas
modificado	`app/core/autenticacion.py`	Hash de contraseñas; en cada petición verifica que el admin siga activo o que el titular no esté anonimizado
modificado	`app/application/use_cases/gestionar_solicitud_arcop.py`	Anonimización al resolver supresión, plazos, filtro de vencidas
modificado	`app/infrastructure/repositories/solicitud_arcop_repository.py`	Varios eventos por transacción, filtro `vencidas`
modificado	`app/api/routes/arcop.py`	Inyecta anonimización/plazos; `?vencidas=true`; plazos en el catálogo
modificado	`app/application/schemas/arcop_schemas.py`	`fecha_limite_respuesta`, `fecha_limite_informacion`, `plazo_vencido`
modificado	`app/domain/models/solicitud_arcop.py`	Columnas de plazos; evento `anonimizacion`
modificado	`app/domain/models/usuario_temporal.py`	Columna `fecha_anonimizacion`
modificado	`app/domain/models/__init__.py`	Exporta `UsuarioAdmin`
modificado	`app/core/config.py`	`ARCOP_PLAZO_RESPUESTA_DIAS`, `ARCOP_PLAZO_INFORMACION_DIAS`
modificado	`app/main.py`	Registra el router `auth`
modificado	`.env.example`, `env.example`	Variables de plazos (comentadas)
modificado	`tests/_api_harness.py`	Siembra un 2.º usuario temporal y un admin de prueba
modificado	`tests/test_solicitudes_arcop.py`	Pruebas de login, anonimización y plazos

Acceso (versión 2)

Quién	Cómo obtiene el token	Body
Usuario temporal (titular)	`POST /api/auth/titular`	`{"usuario_temporal_id": 1, "email": "correo@de.la.invitacion"}`
Administrador	`POST /api/auth/login`	`{"email": "...", "password": "..."}`

- El titular debe tener la invitación vigente (`fecha_expiracion` hoy o después) y no estar anonimizado.
- Los errores son genéricos (401 `CREDENCIALES_INVALIDAS`): no revelan si el email o el id existen.
- En cada petición se verifica en BD que el usuario siga habilitado: desactivar a un admin o anonimizar a un titular corta su acceso de inmediato (401 `USUARIO_DESHABILITADO`).
- El CLI `python -m app.core.autenticacion --usuario N --rol ...` se mantiene **solo para desarrollo**.

Anonimización al aprobar una supresión

Se ejecuta cuando un admin resuelve como `resuelta` una solicitud de tipo `supresion`, **en la misma transacción **que la resolución (o se aplica todo o nada). Es** irreversible**.

Tabla	Se borra	Se conserva
`usuario_temporal`	email, validacion_invitacion; se fija `fecha_anonimizacion`	rubro (benchmark)
`respuestas`	justificacion_usuario	clasificaciones, fuente, confianza
`evidencias` + **archivos**	nombre, ruta, hash, datos extraídos, justificación del LLM, errores; el archivo se borra del disco	estado, clasificación del LLM, confianza
`sanitizaciones`	mapa_cifrado, entidades (huellas)	conteos por tipo
`eventos_seguridad`	extracto, hash del texto	fecha, tipo, origen
`solicitudes_arcop` (todas las del titular)	descripción → `[anonimizado]`; comentarios del titular en el historial	tipo, estados, fechas, respuesta del admin
`respuestas_filtro`, `resumen`, `llamadas_llm`	— (no tienen texto personal)	todo

El historial de la solicitud registra un evento `anonimizacion` con la **cantidad** de filas afectadas por tabla (nunca el contenido). Los archivos se borran después del commit; si alguno falla, queda en el log `arcop` para revisarlo a mano.
Importante para los admin: la `respuesta` de la resolución se conserva, así que no debe contener datos personales del titular.

Plazos (versión 2; reemplazado por la versión 3)

Variable	Qué fija	Columna
`ARCOP_PLAZO_RESPUESTA_DIAS`	días desde que se recibe la solicitud hasta responderla	`fecha_limite_respuesta` (al crear)
`ARCOP_PLAZO_INFORMACION_DIAS`	días que tiene el titular para aportar antecedentes pedidos	`fecha_limite_informacion` (al pasar a `pendiente_informacion`; se limpia al salir)

- Mientras estén **comentadas en el** `.env`, las columnas quedan en `NULL` y no hay vencimientos.

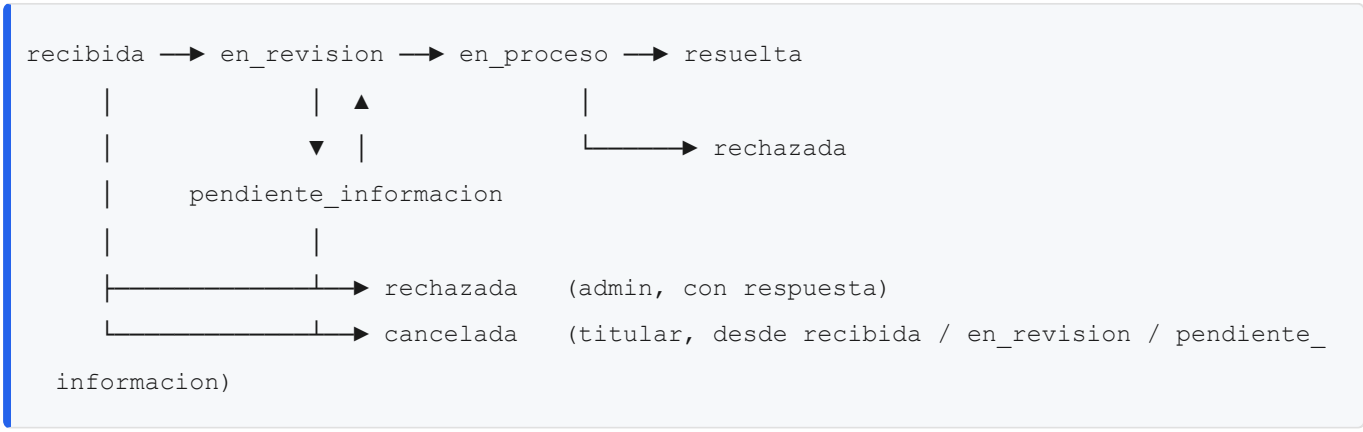
  Ojo: no dejar la variable con `=` vacío (`ARCOP_PLAZO_RESPUESTA_DIAS=`), porque falla al arrancar; hay que comentarla o poner un número.
- Se cuentan en **días corridos** (función `_sumar_dias` del caso de uso; si la ley exige días hábiles, se cambia solo ahí).
- Solo se **informa** el vencimiento: `plazo_vencido` en cada solicitud y `GET /api/arcop/solicitudes?vencidas=true`.

  No hay cierre automático por vencimiento; queda pendiente decidir qué pasa al vencer.
- Las solicitudes creadas antes de configurar un plazo no lo reciben retroactivamente.

Modelo de datos (migración `e5a1c9d4b2f7`, revisa `a168283ff2b8`)

`solicitudes_arcop`: `id_solicitud` PK · `tipo` · `estado` · `descripcion` (texto del titular) · `Usuario_temporal_id` FK → `usuario_temporal.id` (titular) · `fecha_creacion` · `fecha_actualizacion` · `fecha_cierre` · `respuesta` (resolución). CHECK de `tipo` y `estado`; índices por titular y estado. `eventos_solicitud_arcop` (historial): `id_evento` PK · `Solicitudes_arcop_id_solicitud` FK · `fecha` · `tipo_evento` (creada, cambio*estado, informacion*aportada, resolucion, cancelacion) · `estado_anterior` · `estado_nuevo` · `actor_rol` · `actor_id` · `comentario`.
Fechas en UTC sin zona, igual que `eventos_seguridad` y `llamadas_llm`.

Ciclo de vida



`resuelta`, `rechazada` y `cancelada` son finales (fijan `fecha_cierre`, no admiten más cambios).

Acción	Quién	Desde
crear (→ recibida)	titular	—
en_revision	admin	recibida, pendiente_informacion
pendiente_informacion (comentario obligatorio)	admin	en_revision
aportar información (→ en_revision)	titular	pendiente_informacion
en_proceso	admin	en_revision
resolución `resuelta`	admin	en_proceso
resolución `rechazada`	admin	recibida, en*revision, pendiente*informacion, en_proceso
cancelada	titular	recibida, en*revision, pendiente*informacion

Endpoints

Todos menos `/catalogo` y los de `/api/auth` exigen `Authorization: Bearer <token>`. Listado admite además `?vencidas=true`. Errores nuevos: 401 `CREDENCIALES_INVALIDAS`, 401 `USUARIO_DESHABILITADO`.

Método	Ruta	Rol	Respuesta
GET	`/api/arcop/catalogo`	público	tipos, estados y transiciones
POST	`/api/arcop/solicitudes`	referente	201 + detalle
GET	`/api/arcop/solicitudes?page&size&estado&tipo&usuario_temporal_id`	ambos	`{items,total,page,size,pages}`; el titular solo ve las suyas
GET	`/api/arcop/solicitudes/{id}`	ambos	detalle + historial; 404 si es de otro titular
PATCH	`/api/arcop/solicitudes/{id}/estado`	admin_therion	`{estado, comentario?}`
POST	`/api/arcop/solicitudes/{id}/resolucion`	admin_therion	`{resultado: resuelta|rechazada, respuesta}`
POST	`/api/arcop/solicitudes/{id}/cancelacion`	referente	`{motivo?}`
POST	`/api/arcop/solicitudes/{id}/informacion`	referente	`{informacion}`

Errores: 400 validación (texto), 401 `NO_AUTENTICADO` / `TOKEN_INVALIDO`, 403 `NO_AUTORIZADO`, 404 no encontrada, 409 `TRANSICION_INVALIDA` (incluye `estado_actual` y `permitidas`), 503 `AUTH_NO_CONFIGURADA` si falta `AUTH_SECRET`.

Probar a mano (Docker, PowerShell desde `Proyecto`)

```
docker compose up -d --build
  docker compose exec api python -m app.core.crear_admin --email admin@therionlabs.cl
  # pide la contraseña (mín. 12)

  $api = "http://localhost:8000/api"
  $a = Invoke-RestMethod -Method Post "$api/auth/login" -ContentType "application/json"
  `
       -Body '{"email":"admin@therionlabs.cl","password":"<tu contraseña>"}'
  $t = Invoke-RestMethod -Method Post "$api/auth/titular" -ContentType "application/jso
  n" `
       -Body '{"usuario_temporal_id":1,"email":"test@example.com"}'
  $A = @{ Authorization = "Bearer $($a.access_token)" }; $T = @{ Authorization = "Beare
  r $($t.access_token)" }

  $s = Invoke-RestMethod -Method Post "$api/arcop/solicitudes" -Headers $T -ContentType
  "application/json" `
       -Body '{"tipo":"acceso","descripcion":"Solicito copia de mis datos personale
  s."}'
  Invoke-RestMethod "$api/arcop/solicitudes" -Headers $A
  Invoke-RestMethod -Method Patch "$api/arcop/solicitudes/$($s.id_solicitud)/estado" -H
  eaders $A -ContentType "application/json" -Body '{"estado":"en_revision"}'
  Invoke-RestMethod -Method Patch "$api/arcop/solicitudes/$($s.id_solicitud)/estado" -H
  eaders $A -ContentType "application/json" -Body '{"estado":"en_proceso"}'
  Invoke-RestMethod -Method Post "$api/arcop/solicitudes/$($s.id_solicitud)/resolucion"
  -Headers $A -ContentType "application/json" `
       -Body '{"resultado":"resuelta","respuesta":"Se adjunta el detalle de sus dato
  s."}'
```

Con `"tipo":"supresion"` y el mismo recorrido, al resolver se anonimiza el titular: **úsalo con un usuario temporal de prueba**, no con uno que necesites conservar.

Decisiones que requieren confirmación

1. **Identificación del titular.** Invitado: `usuario_temporal_id` + email de la invitación. Encuestado anónimo (v3): `evaluacion_id` + clave de acceso de la evaluación (la entrega HU-19 al iniciar la encuesta). Es tan fuerte como lo secreto que sea el id: si el link de invitación es adivinable, conviene agregar un código de invitación aleatorio.
2. **Sin límite de intentos.** El login no bloquea tras varios intentos fallidos; queda registrado en el log `seguridad`. Si se expone a internet, agregar limitación de intentos.

3. **Plazos (v3).** Se usan 30 días corridos + prórroga única de 30 + bloqueo en 2 días hábiles, según fuentes secundarias sobre la Ley 21.719 (art. 11 de la Ley 19.628 reemplazado). Conviene confirmarlo con el texto oficial en bcn.cl. Pendiente: feriados en los días hábiles, si el plazo se suspende en `pendiente_informacion`, y qué hacer al vencer (el titular puede reclamar ante la Agencia dentro de 30 días hábiles).
4. **Alcance de la anonimización.** Se conservan clasificaciones y puntajes sin vínculo personal; no se tocan los respaldos de la BD. Confirmar si la ley exige más (o permite menos).
5. **Solicitudes abiertas del mismo titular** al anonimizarlo: quedan abiertas y anonimizadas, el titular ya no puede entrar; un admin debe cerrarlas.
6. **Verificación de identidad, excepciones y causales de rechazo** (Ley 21.719): no modeladas.
7. **Duplicados**: se permiten dos solicitudes iguales abiertas a la vez.
8. **Frontend**: no se modificó; el login y la bandeja de admin están disponibles por API.